

Decisions

The choices behind SecureGate v0.1: what we chose, why, and what we rejected. Add an entry whenever you make a choice that someone might question later. Words in bold are explained in the Glossary (glossary.pdf).

1. Gitleaks finds, SecureGate decides

- **Chose:** **Gitleaks** finds candidate secrets; our own `policy.yaml` decides what happens to them.
- **Why:** Gitleaks already knows many key formats and is widely used. What we add is the decision and the safe reporting.
- **Rejected:** writing our own detection rules for every provider; TruffleHog (out of scope for v0.1).

2. One readable policy, first match wins

- **Chose:** rules checked from top to bottom; the first rule that matches decides.
- **Why:** anyone can read the file and predict the result.
- **Rejected:** scores and weights (hard to predict); several policy files.

3. The last rule must match everything

- **Chose:** a policy without a final catch-all rule, or with unknown words in it, is refused (exit code 2).
- **Why:** every finding gets a decision, and a typo can never switch a rule off silently.
- **Rejected:** a hidden default decision.

4. Rule order as specified

- **Chose:** placeholders, then tests/fixtures/docs, then provider keys, then GitHub tokens, then everything else.
- **Consequence:** a real AWS key inside `docs/` or `tests/` only warns. Move the provider rules up if that is not wanted.

5. We mask values ourselves, in memory

- **Chose:** Gitleaks reports raw values into a private temporary folder; we read them into memory, delete the folder, and **mask** them before anything is shown.
- **Why:** the policy must see the raw value to recognize placeholders such as `changeme`.
- **Rejected:** Gitleaks' own redaction (it would hide values from the policy too); keeping reports on disk. A possible improvement: read the report from Gitleaks' normal output, so it never touches the disk.

6. Masking shape

- **Chose:** values of 16+ characters show their first 4 and last 4 characters around `****`; shorter values become `****`.
- **Why:** enough to recognize a key, never enough to use it. The number of stars never changes, so the length stays hidden.

7. Fingerprints use a private key

- **Chose:** HMAC-SHA256, keyed by `SECUREGATE_HMAC_KEY` (at least 32 characters) or a random key stored in `.securegate/local.key`.
- **Why:** a plain hash of a short password can be cracked by hashing guesses. Without the key, a **fingerprint** reveals nothing.
- **Consequence:** the finding id is the start of the fingerprint, so the same secret in two places has the same id. The id names the secret, not the place.

8. Exit codes 0 / 1 / 2, and Gitleaks runs with `--exit-code 99`

- **Why:** Gitleaks normally uses 1 both for "found leaks" and for "crashed". A different number for leaks lets us tell them apart.

9. Fail closed

- **Chose:** any problem ends with exit code 2, never 0.
- **Found during the build:** asked to scan a folder that is not a Git repository, Gitleaks logs an error but exits 0 with an empty report. SecureGate now treats any error output from Gitleaks as a failure.

10. Nothing can silence a finding outside the policy

- **Chose:** `gitleaks:allow` comments in code are ignored, and a `.gitleaksignore` file in the scanned folder stops the scan with exit code 2.
- **Why:** otherwise a developer could hide a leak without the policy ever seeing it.
- **Rejected:** a warning only.

11. Gitleaks is only run from the PATH folders

- **Why:** on Windows, a program in the current folder would run first, and a scanned repository could contain a fake `gitleaks.exe`.

12. The ACME Pay rule has no randomness filter

- **Why:** placeholders like `acme_live_xxxx...` should reach the policy, which decides to ignore them. One place decides.

13. Only third-party folders may be skipped

- **Chose:** `.gitleaks.toml` skips Python virtual environments (installed packages). Our own code is never skipped.
- **Why:** if the scanner flags our code, we fix the code. A test scans our own files on every run.

14. No key-shaped text in our files

- **Chose:** fake secrets are built at runtime from a seed and short pieces; markers like PEM headers too.
- **Rejected:** sample keys stored in test files.

15. The demo repo lives outside SecureGate

- **Chose:** `../securegate-demo`, and never inside any Git repository. `--force` only empties a folder the generator made before; it leaves a `.securegate-demo` marker file there.
- **Rejected:** letting `--force` empty any folder.

16. Same seed, same demo repo

- **Chose:** a seed for every random choice, a fixed author (Riya Demo) and dates, and Git run without your personal Git settings.
- **Why:** results can be compared over time; the same seed gives the same commit IDs.

17. The answer sheet holds no values

- **Chose:** `ground_truth.csv` lists file, line, commit, kind and expected decision, never the value itself.

18. The scorecard is reported, not enforced

- **Why:** tests must not push the rules into looking good. First results (seed 42, repo mode): 15 hits, 2 **misses** (a database password inside a web address, a password with symbols), 1 wrong decision (the AWS secret key only warns: Gitleaks catches it with a generic rule), 2 **false alarms** (a client ID and a commit hash used as a cache key).

19. A simple confidence score, for now

- **Chose:** 0.9 for known key formats; for generic matches, $\text{entropy} \div 6$, at most 0.8.
- **Why:** a placeholder until a learned model replaces it. Confidence never decides anything; only the policy does.

20. findings.json has a summary at the top

- **Chose:** status, exit code, Gitleaks version and counts, then the findings. After an error there is no findings list at all.
- **Why:** a failed scan can never be mistaken for a clean one.

21. Tooling

- **Chose:** Python 3.12 (installed next to 3.14), GNU make from winget, setuptools, pytest and ruff; LF line endings in every file.
- **Why:** these match the plan; LF avoids Windows line-ending noise in Git.

22. Small helper modules added during the build

- `demo/app.py`: the fake app's files and commit story. `programs.py`: finds `git` and `gitleaks` safely. `validate.py`: shared checks for `policy.yaml` and `catalog.yaml`.
- **Why:** one job per module, and no copied code.

23. The dashboard is local and read-only

- **Chose:** a small Flask app that only reads one `findings.json`, answers only on 127.0.0.1 (this computer), and keeps debug off unless `--debug` is given.
- **Why:** findings are sensitive even when masked, so nobody else on the network should reach them, and a report viewer has no reason to change anything.
- **Rejected:** a shared web server, logins and editing (out of scope for now).

24. No JavaScript, and it works offline

- **Chose:** plain HTML and CSS. The Content-Security-Policy header forbids scripts, and every file comes from SecureGate itself.
- **Why:** nothing to download, nothing to break, and nothing for a malicious report to run. It works on a laptop with no internet.
- **Rejected:** JavaScript frameworks and chart libraries.

25. Severity bars are HTML meters

- **Chose:** one `<meter>` element per severity.
- **Why:** screen readers read them as values, and they need no inline styles, which the strict security policy would block.

26. The dashboard checks the masking again

- **Chose:** every `masked_value` must have the masked shape (`****`, or 4 characters + `****` + 4). A report that breaks this is refused, not shown.
- **Why:** a report edited by hand, or written by a future bug, must never put a whole secret on screen.

27. No report means a helpful page

- **Chose:** a missing, broken or failed report shows a page (HTTP 503) with the exact command that creates one. The report is read again for every page.
- **Why:** the first thing a new user sees tells them what to do next, and a new scan appears after a reload.

28. One detail page per secret

- **Chose:** `/findings/<id>` lists every place where that secret was found.
- **Why:** the id names the secret, not the place (see entry 7), and the fix (revoke and replace) is the same for all its places.

29. Design tokens with Fluent 2 names

- **Chose:** every colour, font size, spacing value and radius is a CSS variable in `tokens.css`, named like Fluent 2 tokens. Tests fail if `app.css` uses a raw value, or if text drops below WCAG AA contrast. Screens 1600 pixels and wider (projectors) get larger text and a wider page.
- **Why:** the designers can drop in their Figma tokens by changing values only, without breaking accessibility.

30. The sample report doubles the demo

- **Chose:** `make sample-report` scans a demo repo holding the DemoPay app twice (once under `billing/`), which gives about 20 real findings.
- **Why:** the usual demo scan has only 11 findings, and the designers need real data rather than invented rows.

31. Two gates, and only one of them is the control

- **Chose:** a laptop gate (a pre-commit hook on staged changes) and a merge gate (the `secret-gate` check on every pull request). Only the merge gate is required.
- **Why:** the laptop gate gives the fastest feedback but runs only where it is installed and can be skipped with `--no-verify`. The merge gate runs for every pull request on GitHub.
- **Rejected:** relying on the laptop gate alone.

32. The laptop gate brings its own Python environment

- **Chose:** a pre-commit hook with `language: python` and a small launcher, `tools/precommit_hook.py`, that runs this checkout's SecureGate.
- **Why:** a plain `securegate` command would only work with `.venv` activated, and on Windows a bare `python` is a different Python without SecureGate. After `make hooks` the hook works offline.

33. The merge gate scans every commit of a pull request

- **Chose:** a range scan from the pull request's base to its head, with no path filters on the trigger.
- **Why:** a secret deleted in a later commit is still in the history. A required check with path filters would never run for some pull requests and leave them stuck.

34. The base branch judges each pull request

- **Chose:** the workflow installs SecureGate, and takes `policy.yaml` and `.gitleaks.toml`, from the pull request's base commit.
- **Why:** otherwise a pull request could loosen the policy or change the scanner and pass its own check. Changes to the gate count once merged.
- **Known limit:** a pull request can still edit the workflow file, because GitHub runs the pull request's copy. `merge-gate.md` recommends requiring an approval.
- **Rejected:** `pip install -e .` of the pull request itself, as first specified.

35. Pinned actions and a checked Gitleaks download

- **Chose:** `actions/checkout` and `actions/setup-python` at their latest major version (v7, looked up on 2026-09-30), pinned to full commit SHAs with the version in a comment. Gitleaks comes from its official release, and both the checksums file (its SHA-256 is pinned in the workflow) and the archive are verified before use.
- **Why:** a tag can be moved to other code; a commit SHA cannot. The pinned checksum also protects against a release file being replaced later.

36. The summary is a SecureGate command

- **Chose:** `securegate summary` writes the Markdown for GitHub's job summary, in a step that always runs and never changes the result.
- **Why:** it reuses the dashboard's report checks, so only masked values can reach GitHub's page, and it is tested like the rest of SecureGate.

37. Demo tokens use our invented ACME format

- **Chose:** `securegate demo-token` prints a new random `acme_live_` token each time, and the demo pull request uses only such tokens.
- **Why:** the repository is public. ACME Pay does not exist, so the token unlocks nothing, and GitHub's push protection does not know the format, so the token reaches the pull request and the gate can be shown for real.
- **Rejected:** fake tokens in real formats (Stripe, AWS, GitHub): push protection may stop them, and they look too much like real leaks.

38. The docs are Markdown, with PDF copies

- **Chose:** the pages in `docs/` stay Markdown, and `make docs-pdf` prints each one to `docs/pdf/` with headless Edge, styled with the dashboard's design tokens. A manifest records which version of each page its PDF came from; only changed pages are rebuilt, and a test fails when a PDF is out of date.
- **Why:** GitHub shows Markdown, pull requests can review it, and the gates scan it for secrets. Gitleaks skips PDF files, so PDF-only docs would never be checked.
- **Links between pages** appear in the PDFs as text, such as "Testing (testing.pdf)": the browser would otherwise write this computer's file paths into them.
- **The one diagram** is drawn by Mermaid 12.0.0, loaded from jsDelivr and checked against a pinned hash, so only that step needs the internet.
- **Rejected:** replacing the Markdown with PDFs; reportlab, which would mean laying out every page by hand.